Procedure Rechten van Betrokkenen (Data Subject Rights)

AVG Art. 12-22 — ISO 27001:2022 A.5.34, A.5.33

Documentnummer	ISMS-031
Versie	1.0
Classificatie	Intern
Eigenaar	[Naam Data Protection Officer / Privacy Officer]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ — minimaal jaarlijks]

1. Doel

Deze procedure beschrijft hoe [Organisatienaam] verzoeken van betrokkenen (data subjects) behandelt onder de **Algemene Verordening Gegevensbescherming (AVG) Artikel 12 t/m 22**. Een correcte, tijdige en aantoonbare afhandeling van deze verzoeken is wettelijk verplicht en essentieel voor vertrouwen van klanten, medewerkers en andere betrokkenen.

Betrokkenen hebben onder de AVG de volgende rechten:

Art.	Recht	Korte omschrijving
15	**Inzage**	Recht te weten of en welke persoonsgegevens worden verwerkt
16	**Rectificatie**	Onjuiste gegevens laten corrigeren
17	**Wissen ("vergeten")**	Verwijdering eisen onder voorwaarden
18	**Beperking**	Pauze op verwerking eisen
19	**Kennisgeving**	Doorgeven wijzigingen aan ontvangers
20	**Dataportabiliteit**	Gegevens ontvangen in gestructureerd formaat
21	**Bezwaar**	Bezwaar tegen verwerking (incl. profiling)
22	**Automatische besluitvorming**	Niet uitsluitend automatisch beoordeeld worden

2. Toepassingsgebied

Deze procedure geldt voor **alle verzoeken** van betrokkenen aan [Organisatienaam], ongeacht:

- Het kanaal waarlangs het verzoek binnenkomt (e-mail, telefoon, post, formulier, mondelinge melding)
- De rol van [Organisatienaam] (verwerkingsverantwoordelijke of verwerker)
- De identiteit van de betrokkene (klant, medewerker, sollicitant, websitebezoeker, leverancier, derde)

3. Kanalen voor verzoeken

Betrokkenen kunnen hun verzoek indienen via:

Kanaal	Details
E-mail	privacy@[domein] of info@[domein]
Webformulier	[organisatienaam].nl/privacy/verzoek
Post	[Postadres] t.a.v. Privacy Officer
Telefoon / in persoon	Verzoek wordt schriftelijk vastgelegd door de medewerker die het ontvangt

4. Verantwoordelijkheden

Rol	Verantwoordelijkheid
Privacy Officer / DPO	Eindverantwoordelijk voor tijdige afhandeling. Intake + beoordeling + antwoord.
Proceseigenaar	Levert de benodigde data uit zijn/haar verwerking. Ondersteunt rectificatie/wissen.
IT-beheer	Voert technische uitvoering (export, verwijdering uit systemen, logs, backups).
Directie	Beslist bij escalatie (bijv. weigering verzoek).
Alle medewerkers	Herkent verzoek + stuurt direct door naar Privacy Officer (drempelvrij).

5. Algemene termijnen

Fase	Termijn	Rechtsgrond
Ontvangstbevestiging	Binnen 3 werkdagen	Goede-dienstverlening-verwachting
Identiteitscontrole	Binnen 5 werkdagen	Art. 12(6) AVG
Inhoudelijk antwoord	**Binnen 1 maand** na verificatie identiteit	Art. 12(3) AVG

Verlenging mogelijk (complex verzoek)	+2 maanden, mits gemotiveerd gemeld	Art. 12(3) AVG
Uitzonderingsgrond (weigering)	Maximaal 1 maand, met motivering	Art. 12(5) AVG

Telling start op de dag nadat de betrokkene alle informatie heeft aangeleverd om het verzoek te kunnen afhandelen (inclusief identiteitsverificatie).

6. Proces per verzoek-type

6.1 Inzage (Art. 15)

Wat moet geleverd worden:

- De doeleinden van de verwerking
- De categorieën persoonsgegevens
- Ontvangers of categorieën ontvangers
- Bewaartermijn (of criteria daarvoor)
- Bestaan van de overige rechten
- Recht om klacht in te dienen bij AP / GBA
- Als de gegevens niet van de betrokkene komen: welke bron
- Informatie over eventuele geautomatiseerde besluitvorming
- **Kopie** van de verwerkte persoonsgegevens

Praktische uitvoering:

1. Identificeer alle systemen waar deze betrokkene in voorkomt (via RoPA ISMS-030)
2. Exporteer data per systeem (CRM, HRM, mail-archief, ticketingsysteem, logging)
3. Anonimiseer gegevens van *andere* betrokkenen die mede zichtbaar kunnen zijn (bijv. e-mail-thread-partners)
4. Lever in gestructureerd PDF + optioneel machine-leesbaar formaat (JSON/CSV)

6.2 Rectificatie (Art. 16)

1. Verifieer welke gegevens de betrokkene gecorrigeerd wil zien
2. Controleer juistheid op basis van autoritatieve bron (paspoort, KvK, contract)
3. Pas aan in **alle relevante systemen** (leaf-to-root: CRM → ERP → mail-aanhef-lijsten → externe ontvangers)
4. Informeer ontvangers conform Art. 19 als wijziging aan hen was doorgegeven
5. Bevestig afronding aan betrokkene

6.3 Wissen / "Recht om vergeten te worden" (Art. 17)

Gronden voor wissen:

- Gegevens zijn niet meer nodig voor het oorspronkelijke doel
- Toestemming is ingetrokken en er is geen andere rechtsgrond

- Betrokkene maakt bezwaar en er is geen dwingend gerechtvaardigd belang
- Gegevens zijn onrechtmatig verwerkt
- Wettelijke verwijderingsplicht

Uitzonderingen (kan niet verwijderd worden):

- Uitoefening recht op vrijheid van meningsuiting/informatie
- Naleving wettelijke verplichting (bijv. fiscale bewaarplicht 7 jaar)
- Algemeen belang op gebied van volksgezondheid
- Archivering / wetenschappelijk onderzoek
- Instelling / onderbouwing / verweer tegen rechtsvordering

Praktische uitvoering:

1. Motiveer gronden voor eventuele weigering
2. Bij toestemming: verwijderen uit **alle productiedata** + **actieve backups** waar redelijkerwijs uitvoerbaar (zie callout)
3. Achterblijvende verwijzingen (logs, audit-trails) mogen blijven onder rechtsgrond "gerechtvaardigd belang" (traceerbaarheid) — tenzij disproportioneel
4. Informeer ontvangers (Art. 19) dat wissing is uitgevoerd
5. Documenteer de wissing in het audit-register (wat, wanneer, door wie, op basis waarvan)

> ***Let op: wissing uit backups.*** *De AVG eist "redelijke" inspanning. Backups die op vaste rotatie-schema's worden overschreven, hoeven niet direct gewist te worden, mits:*
>
> - *De gegevens niet worden hersteld in productie*
> - *De bewaartermijn van de backup beperkt is (typisch 30-90 dagen)*
> - *Wisselvoorziening is vastgelegd als "bij restore moet opnieuw wissing plaatsvinden"*

6.4 Beperking van verwerking (Art. 18)

Gedurende de beperkingsperiode mag de data nog opgeslagen blijven, maar niet verder verwerkt worden (behalve met toestemming of voor rechtsvordering).

Praktische uitvoering:

- Markeer gebruiker/record als "beperkt" in de betreffende systemen
- Zorg dat automatische workflows deze gebruiker overslaan
- Bij opheffing: informeer betrokkene voordat de verwerking weer actief wordt

6.5 Dataportabiliteit (Art. 20)

Alleen van toepassing bij:

- Verwerking op basis van toestemming OF overeenkomst
- Geautomatiseerde verwerking
- Gegevens die betrokkene zelf heeft verstrekt

Technisch formaat: gestructureerd, machine-leesbaar, gangbaar (CSV, JSON, XML). Indien technisch mogelijk: rechtstreeks overdragen aan andere verantwoordelijke.

6.6 Bezwaar (Art. 21)

Bij bezwaar tegen verwerking op basis van **gerechtvaardigd belang** (Art. 6(1)(f)):

- Verwerking pauzeren totdat belangenafweging is gemaakt
- Documenteer: zijn onze gerechtvaardigde belangen zwaarwegender dan de belangen, rechten en vrijheden van betrokkene?
- Bij **direct marketing**: bezwaar is altijd absoluut, direct stoppen verplicht

6.7 Geautomatiseerde besluitvorming (Art. 22)

Indien [Organisatienaam] geautomatiseerde besluiten neemt met rechtsgevolgen of significante impact:

- Betrokkene heeft recht op menselijke tussenkomst bij bezwaar
- Betrokkene heeft recht op uitleg over de logica van het besluit
- Betrokkene heeft recht om zijn/haar standpunt naar voren te brengen

7. Identiteitsverificatie

Om te voorkomen dat verzoeken gebruikt worden voor **identiteitsfraude** (uitvissen wat iemand over jou weet), voert [Organisatienaam] identiteitscontrole uit. Proportionaliteit is key: bij een simpele nieuwsbrief-uitschrijving volstaat bevestiging via e-mail-link, bij een uitgebreid inzage-verzoek is meer bewijs nodig.

Verzoek-type	Minimale verificatie
Inzage	Bevestiging via bekend e-mailadres (double opt-in) + uniek verificatietoken
Rectificatie	Idem, plus bron van de correctie (paspoort/contract indien officieel)
Wissen	Idem, eventueel kopie ID-document (BSN-nummer **afdekken**)
Klant/medewerker verzoek	Inloggen in het portaal is voldoende

Kopieën ID-documenten worden nooit langer dan **30 dagen** bewaard dan strikt nodig voor verificatie en direct daarna verwijderd.

8. Weigering van verzoek

Een verzoek kan geweigerd worden als:

- Het verzoek "kennelijk ongegrond of buitensporig" is (Art. 12(5) AVG)
- Een wettelijke uitzondering van toepassing is (Art. 23 AVG)
- Bijvoorbeeld: journalistiek, wetenschappelijk onderzoek, staatsveiligheid, archivering in algemeen belang

Bij weigering:

1. Schriftelijke motivering aan betrokkene
2. Informatie over klachtrecht bij AP / GBA
3. Informatie over beroep bij rechter

4. Documenteer de weigering in het audit-register

9. Logboek verzoeken

Elk verzoek wordt gelogd met:

Veld	Voorbeeld
Datum ontvangst	[DD-MM-JJJJ]
Verzoeker (naam + contact)	[Naam + e-mail]
Kanaal	E-mail / formulier / post
Type verzoek	Inzage / Rectificatie / Wissen / etc.
Verwerkingsverantwoordelijke	Controller / Processor (bij processor: opdrachtgever)
Datum ontvangstbevestiging	[DD-MM-JJJJ]
Datum identiteitsverificatie	[DD-MM-JJJJ]
Datum inhoudelijk antwoord	[DD-MM-JJJJ]
Resultaat	Toegewezen / Deels toegewezen / Afgewezen + reden
Betrokken systemen	CRM, HRM, ...
Ontvangers geïnformeerd (Art. 19)	Ja / Nee / N.v.t.
Doorlooptijd in dagen	[getal]
Verantwoordelijke medewerker	[Naam Privacy Officer]

Logboek wordt **minimaal 5 jaar** bewaard als bewijs van naleving.

10. KPI's en monitoring

KPI	Doel	Meetfrequentie
Gemiddelde doorlooptijd	≤ 20 dagen (met marge op 1-maand termijn)	Maandelijks
% verzoeken binnen termijn afgehandeld	≥ 98%	Maandelijks
% identiteitsverificatie geslaagd op eerste poging	≥ 85%	Kwartaal
Aantal klachten bij AP/GBA over afhandeling	0	Jaarlijks

Awareness-score medewerkers (herkenning verzoek)	≥ 90%	Jaarlijks via training-toets

11. Training en awareness

- Alle medewerkers krijgen **jaarlijks** training over het herkennen en doorsturen van verzoeken
- Proceseigenaren met directe afhandel-verantwoordelijkheid krijgen uitgebreide training over de procedure
- Nieuwe medewerkers doorlopen onboarding-module AVG binnen 30 dagen na indiensttreding

12. Relatie tot andere documenten

- **RoPA** / **Verwerkingsregister** (ISMS-030) — primaire bron om te lokaliseren welke data van betrokkene aanwezig is
- **AVG Privacybeleid** (ISMS-033) — publieksgerichte verklaring die naar deze procedure verwijst
- **Incident Response Plan** (ISMS-019) — koppeling bij datalek met betrokkenen-verzoeken
- **Classificatiebeleid** (ISMS-014) — gevoeligheid per gegevenscategorie bepaalt verwijderings-zorgvuldigheid

13. Ondertekening

Naam Directie	[Naam]
Handtekening	_____
Datum	[DD-MM-JJJJ]
Naam DPO / Privacy Officer	[Naam]
Handtekening	_____
Datum	[DD-MM-JJJJ]